

Kenya Data Protection Act 2019: The 2026 Corporate Compliance Roadmap

What registration, enforcement, and the pending 2025 Amendment Bill actually mean for your organisation

A Digital Asset Defenders Deep-Dive Guide | Updated August 2026

Introduction

The Data Protection Act, 2019 (Act No. 24 of 2019) came into force on 25 November 2019, giving effect to Article 31 of the Constitution of Kenya and establishing the country's first comprehensive data protection regime. Three sets of implementing regulations — covering registration, general processing, and complaints handling — followed in 2021. For its first few years, the Office of the Data Protection Commissioner (ODPC) was widely seen as a young, education-focused regulator. That has changed. By early 2026, Kenya's data protection regime had shifted decisively from awareness-building into structured, financially consequential enforcement, and a new amendment bill working through Parliament is about to raise the stakes further.

This guide sets out where the law actually stands today: who must register, what enforcement now looks like in practice, and the compliance roadmap Digital Asset Defenders uses with clients across banking, fintech, healthcare, and public-sector organisations in Kenya.

Who Has to Register — and Who's Exempt

Under section 18 of the DPA and the Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021 (Legal Notice No. 207 of 2021), no person may act as a data controller or data processor in Kenya without registering with the ODPC. The regulations took effect on 14 July 2022, and registration is handled through the ODPC's online portal.

The general registration threshold is an annual turnover above KES 5,000,000 or more than ten employees. But size-based exemptions do not apply across the board: organisations in roughly eighteen designated sectors — including financial services, telecommunications, healthcare, education, insurance, hospitality, gaming, direct marketing, and CCTV operators — must register regardless of revenue or headcount. If your organisation touches any of these sectors, assume you need to register and confirm from there, rather than assuming a small headcount exempts you.

Practical note

Operating without registration is itself an offence under the Act, independent of any breach or complaint. Registration status is one of the first things the ODPC checks when it opens an inquiry, so it is also one of the cheapest compliance gaps to close.

The Enforcement Reality in 2026

The clearest evidence that the DPA has teeth is in the ODPC's own numbers. Since the Act came into force, the regulator has received over 9,061 complaints, issued 357 determinations, 134 enforcement notices, and 20 penalty notices, and ordered compensation directly to affected data subjects. In 2025 alone the ODPC issued roughly 96 determinations — nearly double the 2024 figure — and in a single announcement in January 2026 it issued 184 compensation orders to individuals whose data had been mishandled, one of the strongest enforcement actions taken by any data protection regulator in Africa to date.

Total administrative fines had exceeded KES 26 million by September 2024, with maximum KES 5 million penalties issued against organisations including Oppo Kenya, Whitepath, and Regus Kenya (the Regus fine was later reduced on appeal, though the High Court upheld the ODPC's underlying enforcement authority). In a more recent set of notices, the ODPC fined three organisations a combined KES 9.375 million: KES 2.975 million against a digital lender for abusive, third-party-data debt collection — a penalty the High Court subsequently upheld — alongside KES 1.85 million and KES 4.55 million penalties against a hospitality venue and a school respectively.

Enforcement is no longer limited to fines. In a January 2026 ruling against a digital lender, the Data Commissioner found the company had posted a former customer's images and personal details on social media without a lawful basis, ordered deletion of the data, and recommended prosecution of the company's directors for obstructing the investigation — exposing individuals, not just the company, to fines of up to KES 5 million or a two-year jail term on conviction. Kenyan courts have separately ordered the deletion of unlawfully collected biometric data, establishing judicial enforcement as a live, practical risk alongside regulatory action.

Core Compliance Obligations

Lawful basis for processing

Every processing activity needs a documented lawful basis under section 30: consent, performance of a contract, compliance with a legal obligation, protection of vital interests, public interest or official authority, or legitimate interests (subject to a balancing test against the data subject's rights). “We’ve always collected this” is not a lawful basis, and it is usually the first thing an ODPC investigator asks for.

Data subject rights

- Right to be informed
- Right of access
- Right to rectification
- Right to erasure (“right to be forgotten”)
- Right to restriction of processing
- Right to data portability
- Right to object

Data Protection Impact Assessments (DPIAs)

Section 31 requires a DPIA before undertaking processing likely to result in high risk to data subjects' rights and freedoms — large-scale profiling, sensitive personal data processing, or new technology deployments are the usual triggers.

Breach notification

Data controllers must notify the ODPC within 72 hours of becoming aware of a personal data breach. Data processors must notify their controller within 48 hours of discovery. Organisations designated as critical-infrastructure operators under the 2024 cybersecurity regulations face a tighter 24-hour notification window. Where a breach poses a high risk to individuals, affected data subjects must also be notified without undue delay, in plain language.

Penalties: What's Currently at Stake, and What's Changing

Violation type	Current exposure
Administrative fine (controller)	Up to KES 5 million or 1% of annual turnover, whichever is lower
Administrative fine (processor)	Up to KES 3 million or 0.5% of annual turnover, whichever is lower
Criminal offences (e.g. unlawful disclosure, unauthorised access, failure to register)	Fines up to KES 3 million and/or imprisonment up to 10 years
Continuing violations	Daily fines of up to KES 10,000
Compensation orders	Ordered directly to affected data subjects, separate from any fine

Watch this space: the Amendment Bill

The Data Protection (Amendment) Bill 2025, currently before Parliament, proposes changing the penalty calculation from “whichever is lower” to “whichever is higher” between the KES 5 million cap and 1% of turnover — a change that would dramatically increase exposure for large organisations, banks, and telecoms. The Bill also introduces new obligations around AI governance and cross-border data-sharing. It has not yet passed at the time of writing, but organisations budgeting for compliance risk in 2026–2027 should plan against the higher figure, not the current cap.

Other 2025–2026 Developments Worth Tracking

- **Draft Conduct of Compliance Audit Regulations** — would formalise the ODPC’s power to conduct desk-based and on-site regulator-led audits, with defined timelines and documentation expectations.
- **Draft Data Sharing Code** — published for consultation in December 2024, intended to govern inter-agency and cross-organisation data-sharing arrangements.
- **ODPC Cloud Policy (December 2024)** — encourages data localisation for entities adopting cloud solutions, particularly for sensitive government and critical-infrastructure data.
- **Kenya–EU adequacy dialogue** — launched in May 2024, the first such dialogue between the EU and an African nation. Kenya’s GDPR-aligned framework strengthens its case; the dialogue remained ongoing as of early 2026.

Step-by-Step Compliance Roadmap

- 1 **Conduct a data audit** — identify every category of personal data you collect, process, store, and share, and with whom.
- 2 **Register with the ODPC** — confirm your sector and size against the registration thresholds and submit an accurate application.
- 3 **Document a lawful basis for every processing activity** — not just a privacy policy, but an internal record you can produce on request.
- 4 **Update privacy policies and notices** to DPA standard, including plain-language explanations of data subject rights.
- 5 **Build data subject request procedures** that can meet statutory response timeframes.
- 6 **Run DPIAs** for high-risk processing activities before they go live, not after.
- 7 **Implement technical and organisational security measures** — encryption, access controls, logging, regular testing.
- 8 **Write and rehearse a data breach response plan**, including the 72-hour ODPC notification workflow.
- 9 **Train staff** on data protection obligations on a recurring basis, not as a one-off induction module.

- 10 Prepare for regulator-led audits** now, given the direction the draft Conduct of Compliance Audit Regulations are heading.

How Digital Asset Defenders Can Help

- DPA gap assessments benchmarked against current ODPC enforcement priorities
- ODPC registration support and sector-threshold determination
- Privacy policy and data subject request procedure development
- Data Protection Impact Assessments (DPIAs)
- 24/7 data breach response, including the 72-hour ODPC notification workflow
- Staff training programmes

The Kenya DPA is no longer a compliance checkbox that regulators quietly enforce in the background. With 184 compensation orders issued in a single month, director-level prosecutions being recommended, and an amendment bill poised to raise financial exposure further, the cost of getting this wrong is now immediate and quantifiable. Contact Digital Asset Defenders to assess where your organisation currently stands.

Sources & Further Reading

- Office of the Data Protection Commissioner (ODPC), Kenya — odpc.go.ke
- Data Protection Act, 2019 (No. 24 of 2019) and the Data Protection (Registration of Data Controllers and Data Processors) Regulations, 2021 (Legal Notice No. 207 of 2021)
- Dawan Africa, “ODPC Issues 184 Compensation Orders to Data Protection Complainants”, January 2026
- Recording Law, “Kenya Data Privacy Laws: DPA 2019, ODPC Enforcement, and 2026 Compliance Guide”
- Xcobeau, “Kenya Cloud & Data Protection Compliance 2026”
- Sentinel Assurance Partners, “Preparing for an ODPC Data Protection Compliance Audit in Kenya”, April 2026
- Capital FM Kenya, “ODPC faults LOLC Kenya over data breach, orders deletion of client data”, April 2026
- Global Law Experts, “Kenya's Data-Protection Enforcement Turn: 2026 Audits”, July 2026
- OLM Law, “Data Protection Compliance in Kenya: 2026 Guide”